



Web Application Security

Part 3

Updated July 23, 2026

Presented at SNU Chennai

Sivasubramanian Natarajan

Recommended Text books

- Web Application Security, Andrew Hoffman (O'Reilly)
- Grokking Web application security, Malcom Macdonald (Manning Books)

Recap

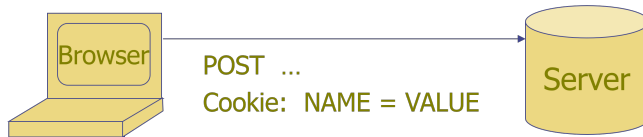
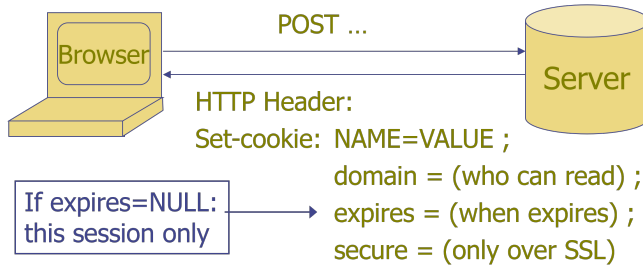
Previous class Summary

- Browser Security (Content Security, Same Origin, Cross Origin Requests, Script Integrity Checks)
- HTTP Request, Response, HTML, DOM, Scripts, Content (Media), CSS
- Javascript Sandbox (What a JS can and cannot do)
- Web Storage and Index DB for storing personalized content like cookies.

Cookies Deep dive

Cookies Overview

◆ Used to store state on user's machine

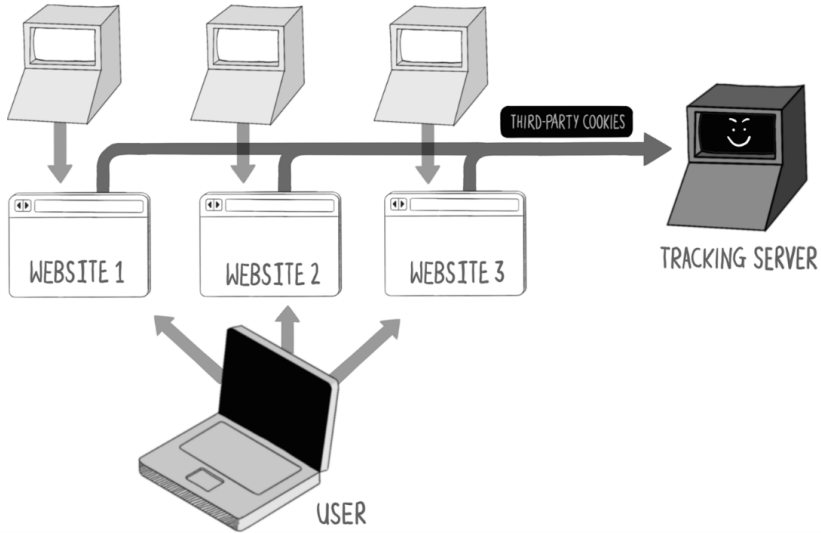


HTTP is stateless protocol; cookies add state

Cookie Attributes

1. Cookies are set in such a way that only HTTPS requests carry the cookies in the 'request object'. "Set-Cookie: session_id=9264be3c7df125; Secure"
2. Prevent JS access "Set-Cookie: session_id=9264be3c7df125; Secure; HttpOnly"
3. Same site Access "Set-Cookie: session_id=9264be3c7df125; Secure; HttpOnly; SameSite=Strict"
4. Send cookie only with 'GET' requests "Set-Cookie: session_id=9264be3c7df1250; Secure; HttpOnly; SameSite=Lax"
5. Cookie Expiry "Set-Cookie: session_id=9264be3c7df12505; Secure; HttpOnly; SameSite=Lax; Expires=Sat, 14 Mar 2026 03:14:15 GMT"
6. Set Max Age "Set-Cookie: session_id=9264be3c7df12505; Secure; HttpOnly; SameSite=Lax; Max-Age=604800"
7. Invalidate Cookie "Set-Cookie: session_id=; Max-Age=-1"

Banning third-party cookies



Browsers and third-party cookies

- Google Chrome: Maintains third-party cookies by default. You can manage and block them by going to Settings > Privacy and security > Third-party cookies and choosing Block third-party cookies.
- Apple Safari: Uses a feature called Intelligent Tracking Protection (ITP). It actively uses machine learning to identify trackers and partition or delete their cookies.
- Mozilla Firefox: Uses Enhanced Tracking Protection (ETP). When set to 'Strict', it automatically blocks known third-party tracking cookies.
- Microsoft Edge: Features built-in Tracking Prevention. Under 'Strict' mode, it actively blocks tracking cookies from sites you have not visited.

Functions in Third-party cookie prevention

- Direct Blocking / Request Rejection: The browser maintains a blocklist of known advertising and tracking domains. If a website tries to load an image, script, or cookie from a domain on the blocklist, the browser stops the request entirely.
- State Partitioning: Instead of a complete block, modern browsers may partition the cookie. This creates a "jar" of cookies specific only to the site you are on. If a tracker attempts to read a cookie set by a different website, the tracker won't find it, rendering cross-site tracking impossible.

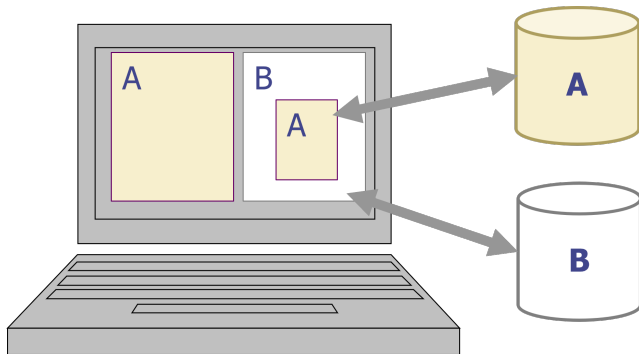
Reference:

https://developer.mozilla.org/en-US/docs/Web/Privacy/Guides/Third-party_cookies

Browser Window management

Browser Frames

- Each frame of a page has an origin "Origin = protocol://host:port"
- Frame can access its own origin "Network access, Read/write DOM, Storage (cookies)"
- Frame cannot access data associated with a different origin

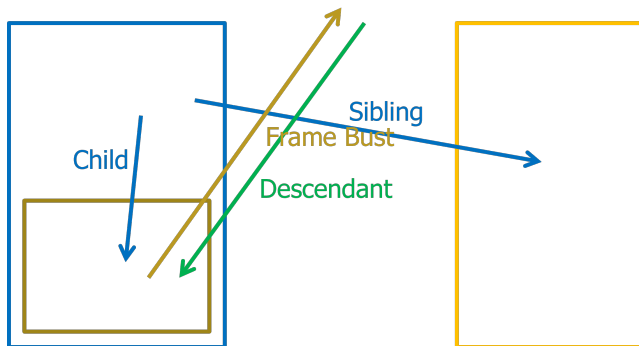


Browser Frames Isolation

- Frame-Frame relationships: Can Frame A execute a script that manipulates arbitrary/nontrivial DOM elements of Frame B?
- Can Frame A change the origin of content for Frame B?
- Can Frame A read/write cookies from site S?

Browser Windows Isolation

- In JavaScript, a child window is a pop-up opened by a parent window using `window.open()`.
- A sibling window refers to another child window opened by the same parent.
- The parent window tracks its children in variables, while siblings communicate by going through their shared parent



Browser Window Operations

- When a parent creates a child, it receives a window reference. The parent can directly access the child's variables or Document Object Model (DOM) elements
- A child window can reference the window that created it using `window.opener`. This allows the child to alter the parent's page or trigger its functions
- Sibling windows do not have direct, built-in access to each other unless managed by a parent. The most common and secure way for siblings to communicate is to send data up to the parent window, which then passes the data to the target sibling

Reference:

<https://developer.mozilla.org/en-US/docs/Web/API/Window/open>